PLANO DE RESPOSTAS AOS RISCOS

NockHug

Sistema de acionamento remoto por comando de voz para máquina lançadora

(protótipo com máquina de bolinhas de pingue-pongue)

FUNDAÇÃO ESCOLA DE COMÉRCIO ÁLVARES PENTEADO - FECAP

Bacharelado em Ciência da Computação

Redes de Computadores e Cibersegurança - Victor Rosseti

Estudantes:

- André Gregório dos Santos – RA: 24026489

- Guilherme Reis Fogolin de Godoy – RA: 24026241

- Pedro Henrique Nascimento Lemos – RA: 23025380

- Yan Ramos Cezareto – RA: 24026005

Turma: 6NACOMP_S

Data: 03/11/2026 **Versão:** 3.6

1. Introdução

O **NockHug** é um projeto de inovação tecnológica voltado à modernização do treinamento de tênis, desenvolvido para proporcionar maior autonomia, praticidade e eficiência aos atletas e treinadores. A solução integra um aplicativo móvel a um microcontrolador ESP32, utilizando comunicação Wi-Fi e Bluetooth Low Energy (BLE) para permitir o controle de uma máquina lançadora de bolas por comandos de voz. Dessa forma, buscamos eliminar interrupções desnecessárias, preservar a concentração do jogador e otimizar o tempo de treinamento.

Considerando a integração entre software, comunicação sem fio e componentes eletrônicos, o desenvolvimento do NockHug exige atenção especial à segurança, à confiabilidade e ao funcionamento do sistema. Este Plano de Respostas aos Riscos apresenta as estratégias e ações estabelecidas pela equipe para prevenir falhas, reduzir vulnerabilidades e aproveitar oportunidades de melhoria, contribuindo para a evolução segura e consistente do projeto.

2. Tabela de Respostas aos Riscos

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
V1	Possível acesso indevido à rede Wi-Fi do ESP32.	**Alto**	Mitigar	1. Manter senha forte e exclusiva no arquivo *segredos.h*, fora do repositório. 2. Testar tentativa de conexão com senha incorreta.	André Gregório dos Santos	04/11/2026	Em Andamento
V2	Tentativa de controlar os motores por HTTP sem autorização.	**Extremo**	Mitigar	1. Validar token antes de aceitar operações de controle. 2. Retornar **401** sem alterar estado ou *seq* em operações válidas com token incorreto. Controle incluído no firmware 2.4.0.	Guilherme Reis Fogolin de Godoy	04/11/2026	Concluído
V3	Tráfego HTTP sem criptografia expõe comandos e credenciais.	**Médio**	Mitigar	1. Implementar autenticação de mensagens sem transmitir o segredo diretamente. 2. Na ausência de criptografia, restringir a rede e formalizar o tratamento do risco residual antes do uso externo.	Pedro Henrique Nascimento Lemos	06/11/2026	Não Iniciado
V4	Reenvio indevido de requisições capturadas (replay).	**Médio**	Mitigar	1. Implementar HMAC com contador ou *nonce* para rejeitar requisições repetidas. 2. Reproduzir tentativas de replay e registrar o resultado.	Yan Ramos Cezareto	06/11/2026	Não Iniciado
V5	Identificação da rede do equipamento facilita tentativas de acesso.	**Médio**	Mitigar	1. Manter o SSID não descritivo *Quadra-Local*. 2. Confirmar a configuração no ESP32 e validar autenticação e senha da rede.	André Gregório dos Santos	04/11/2026	Em Andamento
V6	Comandos enviados fora do fluxo de voz ou do aplicativo.	**Alto**	Mitigar	1. Validar token no próprio firmware para comandos recebidos por Wi-Fi e BLE. 2. Verificar a recusa de comandos diretos sem autorização.	Guilherme Reis Fogolin de Godoy	05/11/2026	Em Andamento
V7	Rajadas de comandos de controle sem limitação de frequência.	**Médio**	Mitigar	1. Aplicar intervalo de **1 segundo por operação limitada**. 2. Retornar **429** em repetição rápida, mantendo emergência e parada fora desse limite. Implementado no código 2.4.0.	Pedro Henrique Nascimento Lemos	05/11/2026	Concluído
V8	Sobrecorrente no circuito de potência de 12 V.	**Baixo**	Prevenir (Evitar)	1. Não energizar os motores antes de verificar a proteção elétrica. 2. Instalar proteção de sobrecorrente dimensionada; sem ela, utilizar somente a simulação.	Yan Ramos Cezareto	04/11/2026	Não Iniciado
V9	Controle por BLE sem proteção de pareamento comprovada.	**Alto**	Prevenir (Evitar)	1. Bloquear o uso do BLE para acionar motor real até validar autorização e vínculo. 2. Testar cliente não pareado e ajustar a proteção da característica GATT.	Guilherme Reis Fogolin de Godoy	05/11/2026	Não Iniciado
V10	Token estático presente em texto no comando BLE.	**Alto**	Mitigar	1. Substituir o envio do token em texto por mecanismo de autenticação de mensagens ou canal protegido. 2. Verificar o formato da escrita BLE e impedir o uso físico inseguro.	Pedro H. N. Lemos e Guilherme R. F. de Godoy	06/11/2026	Não Iniciado

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
V11	Falha de reconhecimento de voz offline ou em segundo plano.	**Médio**	Mitigar	1. Validar reconhecimento no dispositivo com tela bloqueada. 2. Manter botão de parada e comando de emergência independentes da voz.	André Gregório dos Santos	05/11/2026	Em Andamento
V12	Ausência de histórico persistente de recusas e incidentes.	**Médio**	Mitigar	1. Conferir os contadores de recusa já implementados em RAM. 2. Criar exportação mínima de incidentes, sem salvar tokens, para análise posterior.	Yan Ramos Cezareto	06/11/2026	Em Andamento
V13	Rota inválida pode afetar diagnóstico ou estado do sistema.	**Médio**	Mitigar	1. Responder rota inexistente com **400** e JSON de status. 2. Preservar estado, *seq* e último diagnóstico quando não houver token válido. Controle incluído no código 2.4.0.	André Gregório dos Santos e Yan Ramos Cezareto	05/11/2026	Concluído
OPP-001	Oportunidade de validar a solução com a empresa parceira.	**Baixo**	Melhorar (Realçar)	1. Reunir documentação, demonstração e resultados técnicos. 2. Apresentar a proposta de integração para avaliação pela empresa parceira.	Pedro Henrique Nascimento Lemos e Guilherme Reis Fogolin de Godoy	Indefinido	Não Iniciado

3. Detalhamento das Estratégias de Resposta

3.1. Estratégias para Ameaças (Riscos Negativos)

Mitigar — V1, V2, V5, V6, V7 e V13: adotamos controles de credenciais e autenticação no ESP32, tratamento de rotas inválidas e limitação de operações. Para os itens concluídos no código 2.4.0, mantemos a validação em bancada como etapa do acompanhamento.

Mitigar — V3, V4 e V10: planejamos proteger a autenticidade dos comandos com HMAC e contador ou *nonce*, de modo a impedir reenvios indevidos e reduzir a exposição do token em cada requisição. Como esse mecanismo, isoladamente, não criptografa os dados, manteremos restrições de uso até definir uma proteção adequada para os canais HTTP e BLE.

Prevenir (Evitar) — V8 e V9: estabelecemos que a alimentação dos motores em 12 V depende de proteção elétrica verificada e que o controle por BLE não será utilizado com motores reais sem autorização e segurança do vínculo comprovadas. Enquanto essas condições não forem atendidas, utilizaremos a lançadora simulada.

Mitigar — V11 e V12: verificaremos o reconhecimento de voz em segundo plano, a possibilidade de parada independentemente da voz e o registro dos comandos recusados. Vamos complementar os contadores atuais em RAM com um meio de guardar registros essenciais de incidentes.

Aceitar (Ativo): caso algum risco residual de impacto compatível permaneça após o prazo de implementação, registraremos a justificativa, as restrições de uso e a decisão da equipe. Não utilizaremos essa estratégia para liberar acionamento físico sem os controles essenciais de segurança.

Transferir: não adotamos a transferência para os riscos priorizados, pois os controles técnicos e as medidas de segurança do protótipo permanecem sob responsabilidade da equipe.

3.2. Estratégias para Oportunidades (Riscos Positivos)

Melhorar (Realçar) — OPP-001: organizaremos os resultados e a demonstração do NockHug para ampliar a possibilidade de integração com a empresa parceira. Mantemos prioridade Baixa e prazo Indefinido, pois a decisão de avançar com a integração não depende exclusivamente da equipe.

4. Monitoramento e Revisão

Revisaremos o plano diariamente até **06/11/2026**, atualizando os responsáveis, os prazos e os status: **Não Iniciado**, **Em Andamento**, **Concluído** ou **Cancelado**. Também faremos uma revisão antes das apresentações de **17, 18, 19, 23 e 24/11/2026**.

A revisão de **02/11/2026** conferiu o firmware **2.4.0** de três modos: a leitura de *executar()*, a suíte do simulador com o mesmo contrato e a compilação do sketch. Os itens marcados como **Concluído** (V2, V7 e V13) estão no código e nesses testes. Isso não substitui a gravação no ESP32 nem o ensaio com motores. A senha do ponto de acesso e o token não foram substituídos nesta revisão.

4.1. Registro de testes e evidências

Registro de código: 02/11/2026, incorporado a este plano em 03/11/2026. Fonte: *main.ino* do firmware 2.4.0 e o simulador do aplicativo, que segue a mesma ordem de decisão. Comandos: *npm test*, *npm run typecheck* e compilação com a partição Huge APP. Resultado: 128 testes passando, verificação de tipos sem erro e compilação concluída. Nenhum segredo foi registrado aqui.

Teste	Comando / procedimento	Esperado	Obtido
C01	Op válida com token inválido em *executar()*.	Resposta 401, sem alterar *seq*, diagnóstico, estado ou o relógio de 1 s.	Confirmado no fonte e no teste do simulador.
C02	Repetir a mesma operação limitada em menos de 1 s.	200 e depois 429, sem mudar o estado. A recusa não empurra a janela. *ping*, emergência, pausar e desligar ficam de fora.	*LIMITE_OP_MS* = 1000. A terceira tentativa, ainda na janela, também recebe 429. Isenções confirmadas.
C03	Consultar */status* e uma rota inexistente, sem token.	*status* não incrementa *seq*. Rota desconhecida responde 400 e preserva *seq* e o último diagnóstico.	*onNotFound* encaminha a *executar()*. Confirmado no fonte e no simulador.
C04	Watchdog, *ping* e emergência durante uma rajada de *ligar*.	Sem contato por 4 s, a série pausa. Emergência chega a parada segura. 401 e 429 não renovam o contato.	*WATCHDOG_MS* = 4000 e estado PAUSADO no fonte. 401 e 429 não renovam o contato. Emergência isenta confirmada no simulador.
C05	Campos de recusa em *statusJson()*.	Contadores só em memória: total, janela de 60 s, via e instante da última recusa.	*negados*, *negadosJanela*, *ultimoNegadoVia* e *ultimoNegadoMs* presentes. A janela não zera o total. Sem gravação na NVS.
C06	Formato BLE e revisão do código alterado na 2.4.0.	Comando no formato token, operação e argumento. Sem token, *seq* não sobe.	Formato confirmado. HMAC não implementado: V3, V4 e V10 seguem abertos. A revisão não mostrou falha nesse contrato. Na calibração e no checklist, o 429 ainda aparece como falta de resposta.
C07	Suíte do aplicativo e compilação do firmware.	Testes e tipos sem erro; sketch 2.4.0 compilado na partição Huge APP.	128 testes passando, typecheck sem erro, compilação concluída. Placa não gravada.

4.2. O que o acompanhamento mantém aberto

Até a apresentação, os itens abaixo não são tratados como encerrados. O que passar de 06/11/2026 vira risco residual aceito, com a restrição de uso escrita, e não status Concluído.

- **V1.** A senha está fora do repositório, mas ainda contém o nome do projeto. A troca por um valor aleatório fica com o responsável e não entra neste plano.
- **V3, V4 e V10.** O token continua na query HTTP e no texto do comando BLE. O HMAC não foi feito pela metade. Sem ele, esses itens não passam a Concluído.
- **V5.** O fonte anuncia a rede Quadra-Local e o BLE Quadra-XXXX. Isso não autentica. O UUID do serviço ainda identifica o projeto. A placa só muda de nome quando a 2.4.0 for gravada.
- **V8 e V9.** Sem fusível dimensionado e sem pareamento BLE, o acionamento físico dos motores continua evitado, como na seção 3.
- **Voz.** O microfone não identifica quem fala. Com a sessão já armada, outra pessoa ao lado pode disparar o comando.
- **Rede.** Quem já entrou no ponto de acesso pode ocupar o HTTP até o watchdog pausar os motores. Os motores param; a série é interrompida.
- **Estado ARMADO.** Ordena os comandos de quem já tem o token. Não impede quem copiou o token de armar e ligar.
- **V12.** Os contadores de recusa estão em RAM e no serial. Ainda não há histórico que sobreviva ao desligamento.

Comprovação prática. Depois de gravar a 2.4.0, a rede esperada é Quadra-Local e o anúncio BLE é Quadra-XXXX. Cada ensaio na placa entra neste plano com comando, saída obtida, data e evidência (log serial ou captura). A inspeção e os testes automáticos desta seção não substituem esse ensaio.